Yunhai Systems: agent tool standard

1. Recommendation and pilot

The problem. An agent holding a shared admin key followed instructions hidden in a partner's ticket and disabled a customer's webhook. Its prompt told it not to. A prompt cannot enforce a rule; code can.

The recommendation. Build one platform-owned MCP tool standard on Cloudflare Workers, in which trusted code checks every agent action. Prepare a gated pilot with two overseas partners on one Singapore-hosted workflow. Use synthetic data until the cross-border gate passes; launch at week 10 means real traffic for a small, named cohort only.

The core rule. The model proposes an action; our code decides. Every tool call is checked against who is calling, which tenant, which scope, which resource and which task. High-impact writes also need a one-time human approval. This follows Cloudflare's Agent Access Model [S12].

Discovery questions (answered at gate G1, week 2).

Stakeholder	What we need to know
CTO	Which partner workflow proves value? Who owns and funds the standard after the pilot?
Product teams	Can every resource be tied to a tenant in code? Which writes are high-impact?
Security	Which identity providers do we trust? How short can tokens live? How fast is revocation?
Regional operations	Who is on call outside Shanghai hours? Who approves access? Where do logs go?
Partners	Can their MCP clients use short-lived OAuth tokens? Which model providers see tool output?
Legal	What may Shanghai staff see, for what purpose, and under which rules (GDPR, PDPA, UU PDP, US DOJ rule)?

Pilot scope.

- Who: two implementation partners and one low-volume, Singapore-hosted customer workflow.
- Tools: `list_integrations` (read) and `disable_webhook` (write).
- Why Singapore, not the EU: Regional Services supports it [S3]; it shares Shanghai's working day; EU and US need longer legal review of Shanghai access. Business data and approvals stay in Yunhai's Singapore stores, with no Durable Objects. Legal decides at G1 whether Cloudflare log metadata outside Singapore [S4] is acceptable; if not, the pilot stays synthetic.
- Known gaps: no SEA metadata boundary [S4]; Indonesia is not a Regional Services region [S3]; no failover outside Singapore [S2].
- Deferred: more writes (approval and rollback complexity), self-service (contract not proven), EU/US production (separate regional gates), and cross-region failover (residency constraints).

Proposed success criteria (confirm at G1).

Area	Target
Security	No shared or standing credentials. Every call carries a verified identity and tenant. All denial tests pass.
Operations	Access approved within 30 minutes. Revocation works within 5 minutes. P1 incidents acknowledged within 15 minutes, 24x7, by a named regional owner. Handover drill passes.
Adoption	Each partner makes its first call within 5 working days. A second product connects in 10 engineer-days or less.
Reliability	At least 99.5% success in the first two pilot weeks at G1-agreed load; exclude expected policy denials, include system errors.

Architecture

2. How it works, where data lives, and the alternative

Production target (Diagram A; not the local PoC).

- The partner's agent calls the MCP hostname for its region. Regional Services decrypts traffic and runs the Worker only in that region [S1][S2].
- The Worker validates a short-lived, audience-bound OAuth token [S11], then scope, tenant, resource and task; high-impact writes need one-time approval. Limits per tenant and tool are counted per Cloudflare location [S9].
- The Worker reaches the origins in both clouds only through Cloudflare Tunnel [S16]. The origin checks again before any change, so the origin is the final enforcement point.
- Data and audit records stay in the region's own stores. Tool output also goes to the partner's model provider, so that path needs approval too.

Available regional controls and planned stores.

Region	Requires entitlement and verified configuration	Not covered
Singapore	Regional Services [S3]; Yunhai approval state in a Singapore transactional store	No metadata boundary [S4]; no Durable Objects jurisdiction [S5]; no failover abroad [S2]
EU	Regional Services, metadata boundary and Durable Objects jurisdiction [S2][S4][S5]	Shanghai personal-data access needs entity/role and transfer review [S17]
US	Regional Services, metadata boundary and Durable Objects jurisdiction [S3][S4][S5]	Check the US DOJ bulk-data rule
All regions	Each item needs entitlement, configuration and its own verification [S14]	Code and secrets deploy globally [S1]; Access JWT is not localized; review identity, logs and subrequests [S14]

Options compared.

Option	Strengths	Costs	Choose when
A. Gateway on Cloudflare Workers (recommended)	One standard for every product and region; checks run before traffic reaches either cloud; Access, Tunnel and rate limits are managed services	Regional Services is an Enterprise add-on [S2]; Singapore has no metadata boundary or Durable Objects jurisdiction [S4][S5]; code and secrets deploy globally [S1]	Default, in every region where legal accepts the documented controls
B. Gateway in Yunhai's own clouds	MCP gateway, policy and approval store run in each cloud region, so logic and state never leave Yunhai's stores	Up to six deployments (3 regions x 2 clouds) to run and patch; Yunhai builds OAuth, rate limits and audit itself; hard to finish in ten weeks	Legal requires in-country processing that Cloudflare cannot verify, for example Indonesia
C. Each product keeps its own agent API	No platform work now	Repeats the incident; no common control or audit; partners integrate many times	Rejected

A and B share one policy module, tool contract and checklist, so a region can move from A to B without changing the standard. In B, WAF, Access and Tunnel are still Cloudflare processing paths. If a locality rule excludes even those, use approved regional ingress and identity, or stay synthetic. Moving to containers alone does not fix it.

Operations, risks and proof

3. Shanghai gate, support across time zones, top three risks, and the Worker

Shanghai operations gate (Diagram B). Shanghai engineers connect through the Cloudflare One Client with Global Acceleration, run in China by licensed partners [S8]. Cloudflare Access then asks for a stated purpose [S6] and an approval of at most 24 hours [S7]; no one has standing access. Security, legal and regional operations approve each activity; application and CI audit record actions [S14].

Activity	Required before Shanghai does it	If not approved
Deploy	Scoped CI; reviewed build; rollback and CI audit verified	Regional release owner deploys
Debug	Synthetic repro first; revocation tested; fields limited	Regional engineer debugs
Read logs	Approved dataset; forbidden fields denied; audit verified	Regional staff send summaries
Support	Tickets classified; malicious-ticket drill passed	Regional queue handles it

Support across time zones (confirm rota at G1). Each tool has a named owner; handover uses the regional queue.

When (UTC+8)	Who responds
Pilot, 09:00-18:00	Shanghai SRE if the gate has passed, otherwise a Singapore engineer. Singapore on-call approves access.
Pilot, 18:00-09:00	Singapore on-call rota (staff or contracted partner). Kill switch disables the write tool within 5 minutes; Shanghai joins only through Access approval.
EU / US (later)	Regional on-call in local business hours. Shanghai is second line, through the gate; partners escalate through the regional queue.

Risk	How the design handles it
1. A tricked agent misuses valid access (write safety)	No shared keys; short-lived tokens; checks at the Worker and again at the origin; actions limited to the task; destructive tools removed after untrusted content is read [S12]; one-time human approval for high-impact writes.
2. Data leaves its region through a side path	List every path (logs, metadata, model provider, tickets, backups); cite evidence for each; apply the Shanghai gate; stay synthetic until proven.
3. Each team builds its own agent API	One standard and policy module, on by default; a checklist before any new tool; contract tests; an owner for every tool.

The Worker. A local MCP server on a Cloudflare Worker [S10] with one read and one write tool on synthetic data. Tenant and scopes come only from the token. The PoC enforces at the origin on purpose, as the last point before data changes, so a bypassed gateway still cannot write. Production adds the same check in the Worker.

What we try	Result
Unknown or forged token	HTTP 401; no tool runs
Planted-ticket write by reader	Denied; nothing changes
Cross-tenant write	Denied, with the same message as a missing ID
Writer, own webhook	Allowed and audited; safe to repeat

Evidence and limitation. 14 local HTTP/MCP checks and 23 unit tests pass; the ticket scenario tests authorization, not injection detection. Fix first: replace fixed demo tokens with short-lived OAuth tokens [S11], then add task scope and regional audit.

Decision and rollout

4. CTO note, rollout plan and product feedback

CTO note (224 words)

I recommend one platform-owned standard for exposing tools to AI agents, with a gated pilot launch by week ten. Two overseas partners will use it on one Singapore-hosted workflow: listing integrations and disabling a webhook. We use synthetic data until our cross-border gate passes; launch means real traffic only for a small, named Singapore cohort.

The key risk is the one we have already seen: an agent turning instructions hidden in a ticket into a production change. Under this standard, no agent holds a shared admin key. Our code checks every action against the caller's identity, tenant, scope and task, the backend checks again, and high-impact writes need a one-time human approval. Shanghai engineers work through Cloudflare Access with a stated purpose, time-limited approval and verified action audit. A named regional owner covers incidents outside Shanghai hours.

The investment is a platform lead, one product owner, and review time from security, regional SRE and legal, plus Cloudflare Regional Services for in-region production. It replaces a separate agent API in every product. If a region later requires in-country processing, the same policy module can run in our own cloud.

The next milestone is a two-week discovery and security review (gate G1). At week ten we decide whether to launch. After two pilot weeks we assess measured results and decide whether to make it the default.

Weeks / gate	Move on when	Owners
1-2 / G1 Scope	Workflow, targets, identity providers, regional paths and on-call rota are agreed	CTO, platform, products, partners, security, legal, regional ops
3-4 / G2 Design	Synthetic read and write work; denial tests pass; partners use real OAuth tokens	Platform, products, security, partner architects
5-6 / G3 Readiness	Access approval, revocation, rollback, kill-switch and support drills pass	Regional ops, Shanghai SRE, security, legal
7-8 / G4 Rehearse	Partners complete synthetic onboarding and a cross-time-zone handover	Platform, products, regional ops, partners
9-10 / G5 Launch	G3/G4 passed: real traffic for the named Singapore cohort; or extend preparation; or stop	CTO, platform, security, regional ops, products, partners

Owners. Platform team: the standard and policy module. Product teams: their adapters. Regional operations: incidents, on-call and access approval. Partners: client integration. Security and legal: gate decisions. CTO: sponsor. If G3 fails, the pilot stays synthetic; no gate is skipped to meet a date.

Enablement. Partner architects: a two-hour workshop in week 3 with the Worker, denial tests and checklist; in week 7 each partner onboards from the README alone, which tests self-service. Cloudflare field teams: the Worker as a reusable demo, plus the checklist and evidence-pack template.

Feedback to Cloudflare product teams. I would send a short evidence pack: the MCP clients and identity providers tested, onboarding effort, the exact blocker, a synthetic reproduction and its measured impact. The likely signal is that SEA customers need Cloudflare metadata and Durable Object state kept in-region, which today only the EU and US get [S4][S5]. One customer's request is a one-off. It becomes a regional pattern only when several independent customers in the region hit the same blocker, the impact is measured, field teams confirm it, and it is not a configuration gap.

Sources. [S1]-[S17] are listed in CLOUDFLARE_DOCS.md in the repository, checked on 11 October 2026.

Appendix: design-review checklist

Answer every row before an agent can use a new tool

Record: tool and version; owners; reviewers from security, legal and regional operations; region; decision and date; any exception and its expiry.

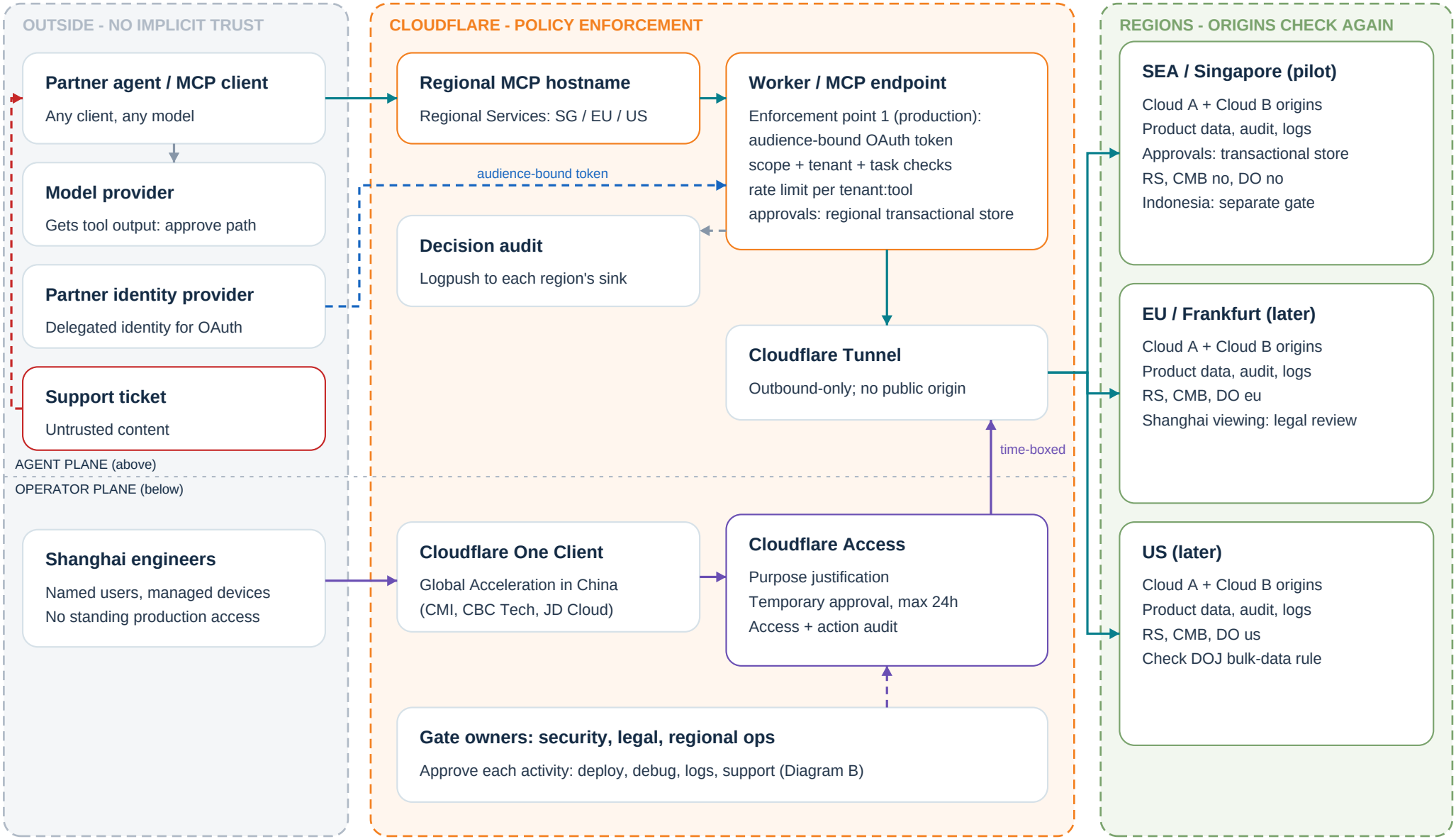
Check	Evidence required
0. Value	Named users, business outcome and owner. Should an agent do this at all?
1. Caller	Trusted identity provider and audience; tenant mapping; token lifetime; revocation tested.
2. Action	One clear action per tool; narrow input schema; required scope; resource ownership checked at the Worker and again at the origin; no shared credential; no free-form URLs.
3. Write safety	Risk level; approval for high-impact writes; replay protection; safe to repeat; rollback; kill switch tested.
4. Untrusted content	Ticket text and tool output cannot grant permission; secrets stay out of model context; injection tests pass.
5. Data and operators	Every data path listed with dated location evidence; Shanghai access approved per activity; legal basis recorded.
6. Operations	Audit in the region with set retention; timeouts, rate limits and alerts; named owner and on-call in every time zone served; partner escalation; contract tests.

Decision: approve this tool, version and region; approve with exceptions that expire; or hold. Missing authorisation, location evidence or cross-border approval blocks production. It is never waived to meet a date.

Minimum evidence: data-flow diagram; permission matrix; allowed and denied requests showing state unchanged; access and incident drills; owner sign-off.

A. Global pilot: three planes, verify before trust

Nothing in the untrusted zone carries authority. In production the Worker checks first; the origin always checks again before any change.



Teal: tool path. Dashed blue: identity. Purple: operator path. Dashed red: untrusted content. Dashed grey: audit.

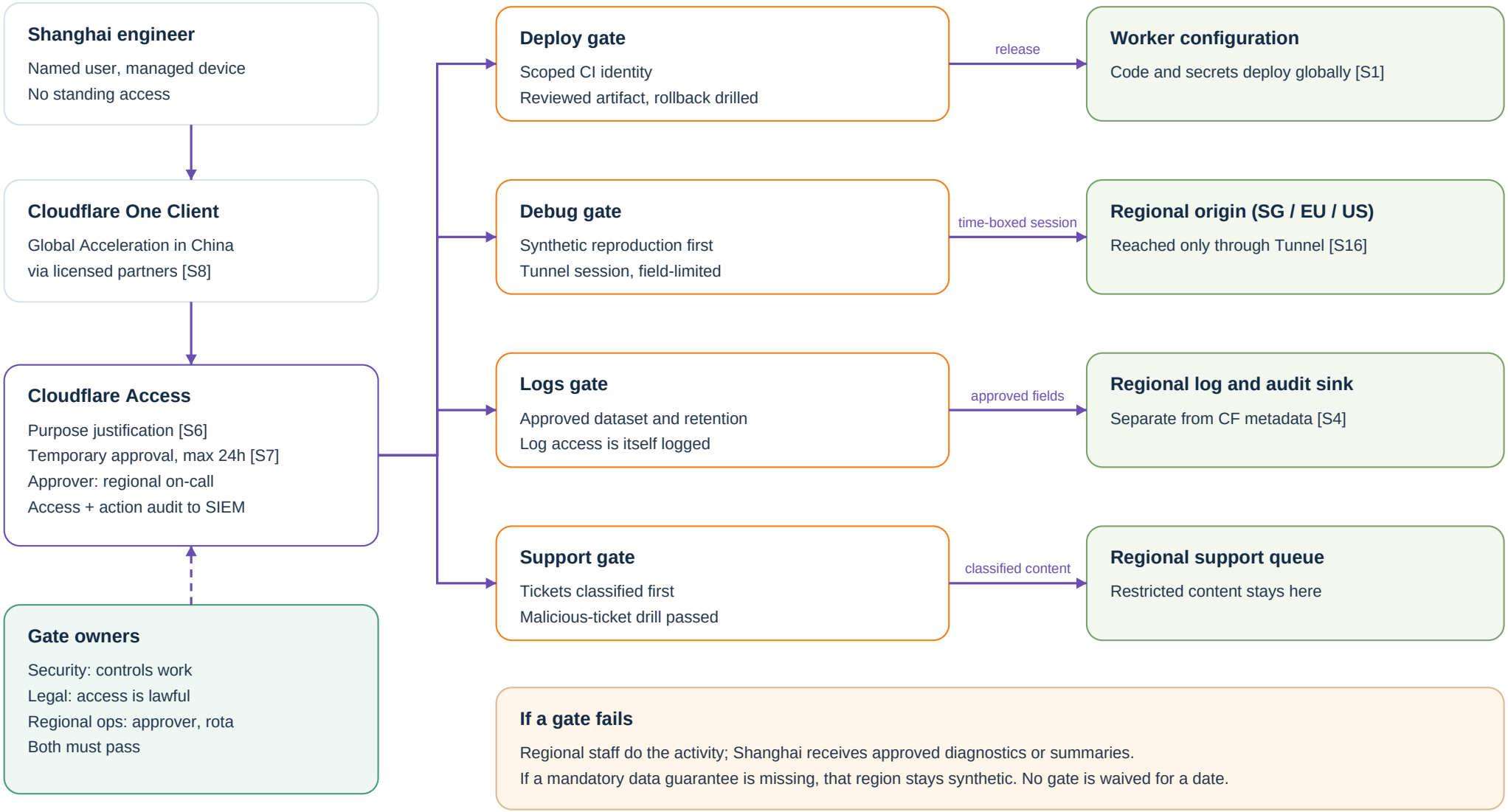
RS = Regional Services region, CMB = Customer Metadata Boundary, DO = Durable Objects jurisdiction [S2]-[S5]. Origins sit behind Tunnel [S16].

Intended boundaries; production requires verified configuration, legal approval and passed gates.

Diagram A

B. Shanghai operator access: zero trust for people, plus a legal gate

No standing access. Each activity needs a purpose, a time-boxed approval, action audit and legal approval of the access.



Technical access control does not establish legal permission. An in-region jump host does not remove cross-border viewing.

Diagram B